
SESIÓN 2 DE 6 · 5 HORAS · BLOQUE 3: 2H15 · DESCANSO 30 MIN · BLOQUE 4: 2H15

CIFRADO SIMÉTRICO Y SUS ERRORES CLÁSICOS

«ESTÁ CIFRADO CON AES-256». ¿Y ESO QUÉ GARANTIZA EXACTAMENTE?

SIO0010 · Técnicas Criptográficas · Especialización en Seguridad de la Información de las Organizaciones · Facultad de Ingeniería · Institución Universitaria de Envigado

SECCIÓN

01

DONDE QUEDAMOS

Entrega del inventario y lo que el inventario reveló

AGENDA DE LA SESIÓN

Hoy es la sesión más práctica del módulo. Al final van a poder mirar una línea de configuración y decir si el dato está protegido o solo parece estarlo.

BLOQUE	MINUTOS	CONTENIDO	MODALIDAD
Bloque 3	0 – 30	Entrega y presentación de la solución del inventario criptográfico	Taller y magistral
	30 – 95	De DES a AES, los modos de operación, el oráculo de relleno y la demostración del escudo	Magistral y demostración
	95 – 135	Los cinco errores clásicos del cifrado simétrico	Magistral
Descanso	30		
Bloque 4	0 – 45	Los tres estados del dato, el cifrado en sobre y cómo buscar sobre datos cifrados	Magistral
	45 – 100	Laboratorio 2: tres ejercicios y el ejercicio en Python	Laboratorio
	100 – 135	Hallazgos H3 y H4 de Coopaburrá, y cierre	Taller y magistral

LO QUE QUEDÓ DEL MARTES

- 01** **La criptografía presta cuatro servicios y no son intercambiables**
Coopaburrá implementó autenticidad cuando lo que el abogado necesitaba era no repudio.
- 02** **La seguridad vive en la llave**
El algoritmo se publica; la llave no. Kerckhoffs, 1883.
- 03** **Una llave sin entropía no es una llave**
Debian 2008 y la consola de 2010: el algoritmo perfecto y el sistema caído igual.
- 04** **Un espacio de llaves grande no basta**
Ochenta y ocho bits de sustitución caen en minutos, porque el ataque no prueba llaves.

// HOY AGREGAMOS LA QUINTA

Un algoritmo correcto, con una llave correcta, puede seguir dejando los datos a la vista si el **modo de operación** está mal escogido. Es el error más frecuente del cifrado simétrico y el que vamos a ver en funcionamiento.

EL INVENTARIO, RESUELTO · 1 DE 2

Así quedó el inventario que construyeron entre todos. Los ocho sistemas de la Parte 3 dan quince usos de criptografía: el portal solo aporta tres. Comparen con el que entregaron.

USO	QUÉ CORRE HOY	SEÑAL
Portal · canal	TLS 1.0–1.2, suites con RSA y 3DES	Obsoleto
Portal · contraseñas	SHA-1 con sal fija (evidencia B)	Obsoleto
Portal · certificado	RSA 2048, SHA-256, de la CA interna	Emisor no confiable
Autoridad interna	Emite y firma certificados	Llave en un escritorio
App · firma de operaciones	HMAC-SHA256, llave compartida	Sin no repudio
App · canal al core	HTTP en claro en el tramo interno (anexo)	Sin cifrar
Core · cifrado de disco	AES-256-XTS (anexo)	Solo con el servidor apagado
Core · base en operación	Ninguno: sin cifrado de campo	Ninguno

EL INVENTARIO, RESUELTO · 2 DE 2

USO	QUÉ CORRE HOY	SEÑAL
Respaldos	AES-256-CBC, llave junto al respaldo	Sin rotar
Cajeros	3DES doble longitud, carga manual (anexo)	Obsoleto · sin rotar
Procesador de tarjetas	TLS 1.3, AES-GCM, autenticación mutua	Correcto
Gestor · firma de pagarés	Ninguno: imagen escaneada	Ninguno · hasta 2039
Gestor · documentos	Ninguno, recurso de archivos	Sin cifrar en reposo
Correo	STARTTLS oportunista, sin DKIM ni DMARC	Suplantable
Directorio local	NT hash (MD4 sin sal), LDAP 389	En claro

// LO QUE CASI NADIE INCLUYÓ

El correo y el directorio: no se sienten «criptográficos», y sin embargo ahí está el MD4, más débil aún que el SHA-1 del portal, y una contraseña que viaja en claro por LDAP en cada inicio de sesión.

LO QUE EL INVENTARIO REVELÓ

Ninguna fila por separado lo dice; el conjunto sí. Esta lectura es lo que el comité necesita, y lo que ninguna casilla suelta muestra.

15

USOS DE CRIPTOGRAFÍA
EN LOS OCHO SISTEMAS

4

SOBRE ALGORITMO OBSOLETO
SHA-1 • 3DES • MD4 • TLS 1.0

10

SIN RESPONSABLE
DE LA LLAVE, CON NOMBRE

0

LLAVES ROTADAS
NUNCA, EN SIETE AÑOS

// EL PATRÓN QUE HAY QUE NOMBRAR

De los cinco usos con algoritmo correcto, cuatro no fallan por el algoritmo sino por la llave: AES, HMAC-SHA256 y TLS 1.3 están bien elegidos, y aun así el respaldo, la firma y el certificado están comprometidos por dónde vive la llave y quién la tiene. **La criptografía de Coopaburrá funciona sin que nadie la gobierne.** Por eso el inventario es la entrega 1 y no la 6, y por eso «desconocido» y «ninguno» son respuestas, no vacíos.

EL MISMO EJERCICIO, EN UNA ORGANIZACIÓN REAL

Coopaburrá tiene ocho sistemas; una organización real tiene cientos. El inventario se topa con estos muros. Ninguno es excusa para no hacerlo: cada uno tiene una salida.

EL MURO	CÓMO SE AFRONTA
«Nadie sabe»	Quien lo montó ya no está y no hay documentación. No se inventa el dato: se marca «desconocido», se nombra a quién preguntar y se reconstruye leyendo configuraciones, tráfico y código. En el caso, la CA en el escritorio del ex contratista.
Son cientos, no ocho	No se hace a mano. Descubrimiento automático —escáneres de TLS, registros de transparencia de certificados, escaneo de secretos en el código— y se prioriza por la sensibilidad del dato, no por el sistema.
Cajas negras de terceros	El proveedor no divulga cómo cifra. Se exige su certificación (PCI, SOC 2, ISO 27001) y se registra bajo responsabilidad compartida. En el caso, el procesador de tarjetas y el correo en la nube.
Criptografía escondida	Llaves incrustadas en el código, en librerías, en dispositivos. Casi nunca está donde dice el diagrama: se encuentra con análisis del código y de dependencias, no preguntando.
El inventario nace viejo	Todo cambia al día siguiente. No es un documento, es un proceso vivo, con dueño y re-escaneo periódico, atado al control de cambios.

CÓMO SE VUELVE VIABLE, Y POR QUÉ YA NO ES OPCIONAL

Lo que hace practicable el inventario a escala, y la razón por la que dejó de ser un lujo de las organizaciones grandes.

// DESCÚBRELO, NO LO ADIVINES

Escáneres de TLS, registros de transparencia de certificados y escaneo de secretos en el repositorio encuentran en horas lo que a mano tomaría meses. La entrevista confirma; no descubre.

// PRIORIZA POR EL DATO

Primero se clasifican los datos y se empieza por lo regulado: personales, tarjetas, salud. Querer inventararlo todo a la vez es no terminar ninguno.

// HAZLO LEGIBLE POR MÁQUINA

Un inventario criptográfico en formato estándar —el CBOM de CycloneDX— se genera en el pipeline y se actualiza solo. Deja de ser una foto que envejece.

// LA RAZÓN DE FONDO ES 2030

La migración post-cuántica obliga a saber dónde está cada algoritmo: no se puede migrar lo que no se ha encontrado. El inventario de hoy es el mapa de esa transición, que verán en la sesión 6.

SECCIÓN

02

CIFRADO SIMÉTRICO

Una sola llave para cifrar y descifrar · AES y los modos de operación

UNA SOLA LLAVE PARA LAS DOS COSAS

Cifrado simétrico significa que la misma llave sirve para cifrar y para descifrar. Es rápido, maduro y es el que protege la inmensa mayoría de los datos del mundo. Su límite es de logística, no de matemáticas.

// LO QUE LO HACE INSUSTITUIBLE

Es entre cientos y miles de veces más rápido que el cifrado de llave pública.

Cifrar un disco de dos terabytes con llave pública sería inviable; con llave simétrica es rutina.

Por eso todo sistema real es híbrido: la llave pública transporta una llave simétrica, y esa hace el trabajo.

// EL PROBLEMA QUE NO RESUELVE

Las dos partes tienen que compartir la llave antes de poder hablar.

Si la comparten mal, todo lo demás sobra.

Y como ambas la tienen, ninguna puede probar ante un tercero qué hizo la otra: por eso el cifrado simétrico nunca da no repudio.

DE DES A AES: POR QUÉ HUBO QUE CAMBIAR

DES fue el estándar durante veinte años. Su algoritmo nunca se rompió de forma práctica: lo que se volvió insuficiente fue el tamaño de su llave. Es la mejor ilustración de que un estándar tiene fecha de caducidad.

AÑO	HECHO	LECCIÓN
1977	DES se adopta como estándar federal de Estados Unidos, con llave de 56 bits	Suficiente para el cómputo de su época
1998	Una máquina de 250.000 dólares de la EFF encuentra una llave DES en 56 horas	El límite era la llave, no el algoritmo
1999	La misma máquina, con miles de equipos en internet, lo logra en 22 horas	El costo del ataque solo baja con el tiempo
2001	AES reemplaza a DES tras un concurso público de cuatro años	Un estándar se reemplaza antes de que caiga, no después
2023	El NIST retira definitivamente el triple DES para cifrar	Veintidós años de transición para sacar un algoritmo viejo

// LA LECCIÓN PARA LA SESIÓN 6

Entre tener el reemplazo y retirar el algoritmo viejo pasaron veintidós años. **Con RSA y las curvas elípticas frente a la computación cuántica el reloj ya corre, y el plazo que se discute es menor.**

AES: QUÉ ES Y QUÉ NO ES

Estándar de cifrado avanzado, adoptado en 2001 tras un concurso público internacional de cinco años. Es el ejemplo perfecto del principio de Kerckhoffs: su diseño es completamente público y lleva veinticinco años resistiendo el análisis de toda la comunidad.

// LO QUE AES SÍ ES

Un cifrador de bloques: transforma bloques de exactamente 16 bytes con una llave de 128, 192 o 256 bits.

El estándar de facto mundial, con aceleración en el procesador de cualquier equipo moderno.

Sin ataque práctico conocido contra el algoritmo en sí.

// LO QUE AES NO ES

No es un sistema de cifrado completo: por sí solo únicamente sabe transformar 16 bytes.

No garantiza integridad ni autenticidad, salvo en los modos que lo añaden explícitamente.

«Cifrado con AES-256» no dice nada sobre la seguridad real si no se dice el modo y cómo se maneja la llave.

EL PROBLEMA DE LOS DIECISÉIS BYTES

AES cifra bloques de 16 bytes. Un archivo tiene millones. Alguien tiene que decidir cómo se encadenan esos bloques, y esa decisión —el modo de operación— importa más que el algoritmo.

LA PREGUNTA QUE RESUELVE EL MODO DE OPERACIÓN

Un archivo de 1 MB = 65.536 bloques de 16 bytes

AES sabe cifrar UN bloque. ¿Qué se hace con los otros 65.535?

- Opción A: cifrar cada uno por separado, igual → modo ECB
- Opción B: encadenar cada bloque con el resultado anterior → modo CBC
- Opción C: cifrar un contador y combinarlo con el dato → modo CTR
- Opción D: como C, y además calcular una etiqueta de autenticación sobre todo el mensaje → modo GCM

// LA FRASE QUE HAY QUE RECORDAR

El algoritmo lo elige el estándar; **el modo lo elige quien programa**. Y ahí es donde se pierde la seguridad en la práctica.

QUÉ HACE AES CON ESOS DIECISÉIS BYTES

No hace falta saber implementarlo, pero sí entender la idea, porque explica por qué es rápido y por qué resiste. AES aplica varias rondas de cuatro operaciones que mezclan y difunden.

OPERACIÓN	QUÉ HACE	PARA QUÉ SIRVE
Sustitución de bytes	Cada byte se reemplaza según una tabla fija y pública	Introduce no linealidad: impide despejar el dato con álgebra sencilla
Desplazamiento de filas	Los bytes del bloque cambian de posición	Difunde: un byte de entrada acaba influyendo en muchos de salida
Mezcla de columnas	Cada columna se combina consigo misma	Difunde todavía más, dentro del bloque
Suma de la llave de ronda	Se combina el bloque con una llave derivada de la principal	Es lo único que depende del secreto

// EL DATO QUE IMPORTA PARA LA PRÁCTICA

Todo lo anterior es público y está en el estándar. Lo único secreto es la llave, y por eso cambiar un bit de la llave cambia por completo la salida. **Diez, doce o catorce rondas según la longitud de llave.**

128, 192 O 256: CUÁNDO IMPORTA

Pregunta frecuente, con una respuesta menos dramática de lo que la gente espera.

LONGITUD	INTENTOS PARA AGOTARLA	CUÁNDO SE JUSTIFICA
AES-128	Del orden de $3,4 \times 10^{38}$	Inalcanzable con tecnología clásica. Suficiente para la mayoría de los datos
AES-192	Del orden de $6,3 \times 10^{57}$	Poco usado. Existe sobre todo por requisitos normativos específicos
AES-256	Del orden de $1,2 \times 10^{77}$	Datos de vida larga y entornos regulados. Es la elección por defecto cuando el costo no importa

// LA RESPUESTA HONESTA

Nadie ha roto AES-128 ni está cerca. Subir a 256 es barato, así que se hace por prudencia y por norma, no porque 128 esté en riesgo. **Discutir la longitud de llave mientras la llave está incrustada en el código es el tipo de conversación que le costó \$71 millones a Coopaburrá.**

ECB: CADA BLOQUE POR SU CUENTA

El modo más simple: se parte el dato en bloques y se cifra cada uno con la misma llave, de forma independiente. Es rápido, se puede paralelizar y es la opción por defecto de muchas bibliotecas antiguas. Tiene un defecto que se ve a simple vista.

LA PROPIEDAD QUE LO ARRUINA

Bloques iguales de entrada → bloques iguales de salida

```
«SALDO: 1000000» → A7F3... 丿  
«SALDO: 1000000» → A7F3...  ┌ siempre el mismo resultado  
«SALDO: 1000000» → A7F3...  └
```

// LA CONSECUENCIA

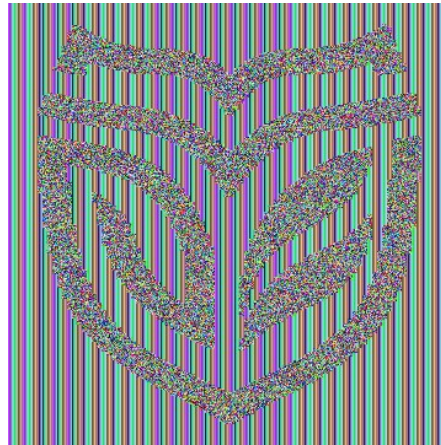
El cifrado oculta el contenido de cada bloque, pero **no oculta la estructura del dato**: los patrones del original sobreviven intactos en el texto cifrado. En la siguiente diapositiva lo vamos a ver con algo que todos reconocen.

EL ESCUDO DE LA INSTITUCIÓN

Tomamos el escudo de la IUE, lo guardamos como imagen y ciframos los píxeles con AES-256, conservando solo la cabecera del archivo para poder abrirlo. Llave de 256 bits generada al azar. A la izquierda el original; a la derecha, el mismo escudo cifrado en modo ECB.



ORIGINAL
SIN CIFRAR

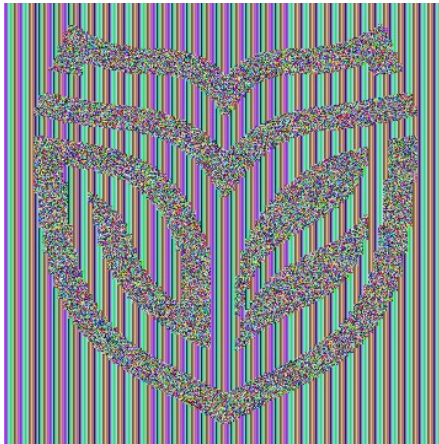


CIFRADO CON AES-256
EN MODO ECB

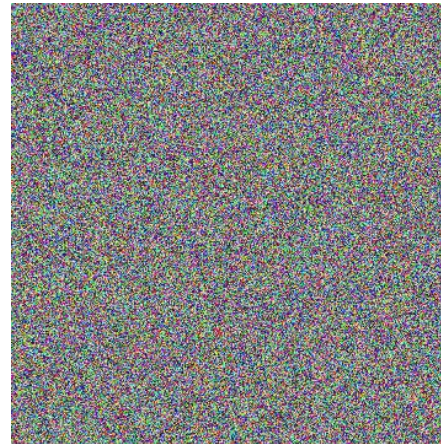
Esto está cifrado con AES-256, el mismo algoritmo que protege secretos de Estado. Y el escudo se sigue reconociendo perfectamente.

EL MISMO ESCUDO, EL MISMO ALGORITMO, OTRO MODO

Idéntica imagen, idéntico AES-256, idéntica longitud de llave. Lo único que cambió fue el modo de operación: en vez de cifrar cada bloque por separado, cada bloque se encadena con el resultado del anterior.



MODO ECB
CADA BLOQUE POR SEPARADO



MODO CBC
BLOQUES ENCADENADOS

La diferencia no está en el algoritmo ni en la llave. Está en una decisión de una línea de código que muchas veces se toma sin pensar.

POR QUÉ PASA ESO

El escudo tiene grandes zonas de un solo color. Cada zona uniforme produce bloques de entrada idénticos, y en ECB los bloques idénticos producen salidas idénticas. El contorno del escudo queda dibujado por la frontera entre zonas.

// LO QUE ECB SÍ OCULTA

El valor concreto de cada píxel. Nadie puede saber que el naranja era exactamente ese naranja.

Cada bloque, tomado aislado, es indescifrable sin la llave.

// LO QUE ECB NO OCULTA

Qué bloques se repiten y dónde. Es decir: la estructura, los patrones y la forma.

En una imagen se ve. En una base de datos también: todos los registros con el mismo saldo, la misma ciudad o el mismo estado se delatan solos.

// DONDE ESTO IMPORTA DE VERDAD

No en imágenes: casi nadie cifra imágenes con ECB. Importa en **bases de datos cifradas campo por campo**, donde permite contar cuántos registros comparten un valor y, con eso, deducir cuál es.

CBC Y EL VECTOR DE INICIALIZACIÓN

Encadenamiento de bloques: antes de cifrar, cada bloque se combina con el texto cifrado del bloque anterior. El primero no tiene anterior, así que se le da un valor de arranque: el vector de inicialización.

ASPECTO	REGLA	SI SE INCUMPLE
El vector es público	Viaja junto al texto cifrado. No es secreto y no hace falta que lo sea	Nada: es correcto que se conozca
El vector debe ser impredecible	Se genera al azar para cada mensaje, con un generador criptográfico	Un atacante puede comprobar si adivinó el contenido de un mensaje
El vector nunca se repite con la misma llave	Cada cifrado, un vector nuevo	Dos mensajes iguales se delatan, y vuelve el problema del martes: la llave repetida
CBC no da integridad	Detecta ruido, no manipulación deliberada	Un atacante puede alterar el texto cifrado para producir cambios controlados en el claro

EL RELLENO Y POR QUÉ EXISTE

AES cifra bloques completos de 16 bytes. Si el dato no es múltiplo exacto, hay que completarlo. Ese relleno parece un detalle administrativo y ha sido el origen de ataques muy serios.

POR QUÉ SOBRAN BYTES Y CÓMO SE COMPLETAN

Mensaje de 29 bytes → dos bloques (32) y sobran 3 por llenar

[bloque 1: 16 bytes][bloque 2: 13 de dato + 3 de relleno]

El esquema habitual rellena con el número de bytes añadidos: 03 03 03

Al descifrar se lee el último byte y se quita esa cantidad.

// EL PROBLEMA

Al descifrar hay que verificar que el relleno sea válido.

Si el sistema responde distinto cuando el relleno es inválido, con otro mensaje de error o con otro tiempo de respuesta, esa diferencia revela información.

// EL ORÁCULO DE RELLENO

Con esa diferencia observable, un atacante puede descifrar el mensaje byte por byte sin conocer la llave, enviando textos modificados y mirando la respuesta.

Es un ataque contra el sistema, no contra AES. Los modos autenticados lo eliminan de raíz.

EL ORÁCULO DE RELLENO

El relleno parece un detalle de formato. En 2002 Serge Vaudenay mostró que puede bastar para descifrar un mensaje completo sin conocer la llave, y el ataque ha reaparecido en productos reales durante veinte años.

UN SERVIDOR QUE DICE DEMASIADO

1. El atacante intercepta un mensaje cifrado en CBC.
2. Lo altera ligeramente y lo reenvía al servidor.
3. El servidor responde distinto según el relleno sea válido o no:
«relleno incorrecto» frente a «error de la aplicación»
4. Esa única diferencia, un bit de información por intento, basta.

Con unos 128 intentos por byte en promedio, el atacante recupera el texto claro completo, byte a byte, sin haber tocado nunca la llave.

// POR QUÉ ESTO CONDENA A CBC SIN AUTENTICAR

El servidor se convierte en un oráculo que responde preguntas sobre el texto claro: es el ataque de texto cifrado elegido de la sesión 1, en acción. **Con un modo autenticado, el mensaje alterado se rechaza antes de mirar el relleno** y el oráculo desaparece. POODLE, en 2014, fue una variante sobre el canal seguro.

CTR Y GCM: DE CIFRAR A CIFRAR CON GARANTÍA

CTR convierte el cifrador de bloques en un cifrador de flujo: cifra un contador y combina el resultado con el dato. GCM hace lo mismo y además calcula una etiqueta de autenticación sobre todo el mensaje. Esa etiqueta es la diferencia entre confidencialidad y protección.

// MODO CTR

Rápido, paralelizable, no necesita relleno y permite acceso aleatorio al dato cifrado.

Da confidencialidad y nada más.

Comparte con CBC la regla de oro: el valor del contador nunca se puede repetir con la misma llave.

// MODO GCM . CIFRADO AUTENTICADO

Da confidencialidad e integridad en una sola operación, y permite autenticar datos que van en claro, como una cabecera.

Si alguien altera un solo bit del texto cifrado, el descifrado falla en vez de devolver basura.

Es el modo que hoy se debe usar por defecto, salvo que exista una razón documentada para otro.

GCM POR DENTRO: LA ETIQUETA Y LOS DATOS ASOCIADOS

Vale la pena ver qué produce GCM exactamente, porque de ahí salen dos preguntas de auditoría que casi nadie hace: qué pasa con la etiqueta y qué se autentica sin cifrar.

CIFRADO AUTENTICADO CON DATOS ASOCIADOS

Entrada: llave · vector único de 96 bits · texto claro · datos asociados

Salida: texto cifrado + etiqueta de autenticación de 128 bits

Al descifrar se recalcula la etiqueta sobre el cifrado y los datos asociados.

Si no coincide no se entrega NADA: ni siquiera un texto claro parcial.

// LOS DATOS ASOCIADOS

Datos que no necesitan ser secretos pero no pueden alterarse: el número de cuenta, la versión del registro, el identificador del asociado.

Viajan en claro, pero la etiqueta los cubre. Así se impide mover un saldo cifrado válido al registro de otro asociado.

// LAS DOS PREGUNTAS DE AUDITORÍA

¿Se verifica la etiqueta antes de usar el dato, o se usa lo descifrado y se verifica después? Lo segundo es un error grave y frecuente.

¿Se recortó la etiqueta para ahorrar espacio? Por debajo de 96 bits la protección se debilita rápido.

CIFRADOS DE FLUJO MODERNOS: CHACHA20-POLY1305

AES no es la única opción moderna. En teléfonos y equipos sin aceleración por hardware manda otra construcción.

CRITERIO	AES - GCM	CHACHA20 - POLY1305
Tipo	Cifrado de bloque en modo contador, con autenticación	Cifrado de flujo con autenticador integrado
Rendimiento	Muy alto cuando el procesador tiene instrucciones para AES	Muy alto en software puro, sin hardware especial
Ataques de temporización	Sin hardware, la implementación puede filtrar información por tiempos	Diseñado para ser de tiempo constante en software
Dónde aparece	Servidores, discos y la mayoría de los protocolos	Canal seguro en teléfonos y redes privadas modernas, como WireGuard
Regla del número único	Nunca repetir el vector con la misma llave	Exactamente la misma regla

// PARA EL INVENTARIO

Si aparece ChaCha20-Poly1305 en una configuración, no es un hallazgo: es una elección correcta. **Lo que sí es hallazgo es un cifrado de flujo sin autenticador, como RC4, que el canal seguro prohibió en 2015.**

CUÁL USAR Y CUÁNDO

MODO	CONFIDENCIALIDAD	INTEGRIDAD	CUÁNDO USARLO
ECB	Parcial: filtra estructura	No	Nunca. No existe un caso legítimo en un sistema nuevo
CBC	Sí, con vector correcto	No	Solo por compatibilidad con sistemas existentes, y siempre acompañado de un código de autenticación
CTR	Sí, con contador único	No	Cuando se necesita acceso aleatorio y se añade autenticación aparte
GCM	Sí	Sí	Por defecto. Es la respuesta correcta mientras no haya un motivo escrito para otra

// CÓMO SE AUDITA ESTO EN UNA ORGANIZACIÓN

La pregunta no es «¿está cifrado?». Son tres: **qué algoritmo, qué modo y de dónde sale el vector de inicialización**. Con esas tres respuestas se sabe si el dato está protegido o solo parece estarlo.

SECCIÓN

03

LOS ERRORES QUE SE REPITEN

Cinco formas de arruinar un cifrado correcto

REPETIR EL VECTOR O EL CONTADOR

Es el mismo error del martes con otro disfraz. Si dos mensajes se cifran con la misma llave y el mismo vector, la protección desaparece parcialmente, y en modo CTR desaparece por completo.

EL MISMO ERROR DEL CUADERNO DE UN SOLO USO, CON AES

En modo CTR, con la misma llave y el mismo contador:

$$\begin{aligned} C1 &= M1 \text{ XOR flujo} & C2 &= M2 \text{ XOR flujo} \\ C1 \text{ XOR } C2 &= M1 \text{ XOR } M2 & \leftarrow & \text{el flujo desaparece, la llave nunca se usó} \end{aligned}$$

Quien tenga los dos textos cifrados obtiene una relación directa entre los dos mensajes en claro, sin conocer jamás la llave.

// DÓNDE APARECE EN LA VIDA REAL

En sistemas que generan el vector a partir del identificador del registro, de la fecha, o de un contador que se reinicia cuando el servicio se reinicia. Los tres son predecibles y los tres se repiten.

CIFRAR SIN AUTENTICAR

El segundo error más frecuente y el menos intuitivo: mucha gente supone que si un dato está cifrado, nadie puede modificarlo de forma útil. Es falso.

// LO QUE LA GENTE SUPONE

«Si está cifrado y alguien lo altera, al descifrar sale basura y nos damos cuenta.»

En algunos modos sale basura. En otros, no: el atacante puede producir cambios controlados en el texto claro sin conocer la llave.

// LO QUE REALMENTE PASA

En modos de flujo como CTR, cambiar un bit del texto cifrado cambia exactamente ese bit del texto claro.

Si el atacante sabe dónde está el campo del monto, puede alterarlo sin descifrar nada.

La solución no es cifrar mejor: es añadir autenticación, o usar un modo que ya la traiga.

ALTERAR UN MONTO SIN CONOCER LA LLAVE

Así se ve el error 2 en un caso concreto: un registro de transferencia cifrado en modo CTR, sin autenticación, y un atacante que conoce el formato del registro pero no la llave.

MANIPULACIÓN CONTROLADA DE UN CIFRADO SIN AUTENTICAR

Texto claro: VALOR=0000100000 (cien mil pesos)
Cifrado CTR: cada byte del texto claro XOR un byte del flujo de la llave

El atacante sabe que el séptimo byte es el primer dígito del monto.
Calcula «0» XOR «9» = 0x09 y lo aplica sobre ese byte del CIFRADO.

Al descifrar: VALOR=9000100000 (más de nueve mil millones)

No descifró nada. No conoce la llave. El descifrado no reporta ningún error.

// LO QUE LO HABRÍA IMPEDIDO

Con GCM, cambiar un solo bit invalida la etiqueta y el registro se rechaza completo. **Con CBC tampoco se evita:** el ataque cambia un poco, pero existe. Por eso la respuesta es cifrado autenticado, no otro modo sin autenticar.

ECB EN PRODUCCIÓN: EL CASO ADOBE

En 2013 se filtró una base de datos con unos 150 millones de registros de usuarios. Las contraseñas no estaban resumidas con una función de una vía: estaban **cifradas** con un algoritmo de bloques en modo ECB y una sola llave.

CONSECUENCIA

POR QUÉ

Dos usuarios con la misma contraseña tenían el mismo texto cifrado

Es exactamente la propiedad del escudo: bloques iguales producen salidas iguales

La pista de recuperación viajaba en claro

Cada registro incluía la pregunta de recuperación sin cifrar, junto al texto cifrado

Se pudieron deducir contraseñas sin romper el cifrado

Agrupando los textos cifrados repetidos y leyendo las pistas de todo el grupo, la contraseña se deducía por votación

// LA LECCIÓN PARA EL CASO

Nadie rompió el algoritmo. La llave nunca se conoció. Y aun así millones de contraseñas quedaron expuestas, por el modo de operación y por haber cifrado algo que nunca debió cifrarse sino resumirse. Eso último lo vemos el martes, con el hallazgo H1 de Coopaburrá.

UNA SOLA LLAVE PARA TODO

El cuarto error no es de algoritmo ni de modo: es de diseño. Usar la misma llave para propósitos distintos convierte cualquier filtración parcial en una filtración total.

SÍNTOMA	CONSECUENCIA	DÓNDE APARECE EN EL CASO
Una llave para todos los usuarios	Comprometer un solo dispositivo compromete a los 142.000	H2 · la llave de la aplicación móvil
Una llave para cifrar y para autenticar	Interacciones entre los dos usos que pueden filtrar información	No documentado; hay que preguntarlo
Una llave para todos los entornos	La llave de pruebas, que circula libremente, abre producción	Por verificar con la fábrica de software
Una llave que nunca cambia	El daño de una filtración es retroactivo e ilimitado en el tiempo	H2 desde 2023 y H6 desde 2019

// EL PRINCIPIO

Una llave, un propósito, un ámbito y un periodo. Cuando alguna de esas cuatro cosas se comparte, la pregunta sobre qué pasa si la llave se filtra deja de tener una respuesta acotada.

LA LLAVE A LA VISTA

El quinto error no es de criptografía sino de dónde termina la llave. En Coopaburrá aparece en tres lugares.

DÓNDE APARECE	POR QUÉ ES GRAVE	EN EL CASO
Escrita en el código fuente	Queda en el repositorio para siempre, en cada copia	La sal constante de H1, visible para once personas
En la línea de comandos	La ve cualquiera que liste los procesos mientras corre	El guion de respaldo, cada noche: evidencia C
En un archivo junto al dato	Quien obtiene el dato obtiene la llave	llave.txt, en el mismo directorio del respaldo
En variables de entorno o registros	Se filtra en volcados de error y en monitoreo	No documentado: hay que preguntarlo
En el paquete de una aplicación	Cualquiera la extrae descompilando el paquete	La llave de firma desde 2023: evidencia D

// DÓNDE DEBE ESTAR

En un servicio de gestión de llaves o en un módulo de hardware, al que el proceso se autentica para pedir que se cifre o descifre, **sin que la llave llegue nunca a la memoria de la aplicación**. La llave no se guarda: se pide. Es la sesión 6.

LA MEJOR DEFENSA CONTRA LOS CINCO ERRORES

Los cinco errores tienen algo en común: son decisiones que alguien tomó mientras programaba. La defensa más efectiva no es capacitar mejor a cada programador, sino quitarle las decisiones.

NIVEL DE LA LIBRERÍA	QUÉ DECIDE QUIEN PROGRAMA	QUÉ ERRORES QUEDAN POSIBLES
Primitivas de bajo nivel	El algoritmo, el modo, el vector, el relleno y la autenticación	Los cinco
Cifrado autenticado · AES-GCM, ChaCha20-Poly1305	El vector y dónde guardar la etiqueta	El 1 y el 5
Recetas de alto nivel · Fernet, secretbox	Nada: pasa la llave y el dato, y la librería resuelve el resto	Solo el 5: dónde vive la llave

// LA RECOMENDACIÓN PARA CUALQUIER EQUIPO DE DESARROLLO

Usar el nivel más alto que resuelva el problema. **Cada decisión que la librería toma por el programador es un error que el programador ya no puede cometer.** Es lo que van a comprobar en el ejercicio en Python.

SECCIÓN

04

LOS TRES ESTADOS DEL DATO

Bloque 4 · Reposo, tránsito y uso: qué protege cada cifrado y contra quién

UN DATO ESTÁ SIEMPRE EN UNO DE TRES ESTADOS

Cada estado exige un mecanismo distinto, y proteger uno no protege los otros. Confundirlos es exactamente el hallazgo H3 del caso.

ESTADO	QUÉ SIGNIFICA	MECANISMO	CONTRA QUIÉN PROTEGE
En reposo	Almacenado en disco, respaldo o archivo	Cifrado de disco, de base de datos o de campo	Quien se lleve el medio físico o acceda al archivo
En tránsito	Viajando por una red	Protocolos de canal seguro	Quien intercepte la comunicación
En uso	Cargado en memoria mientras se procesa	Entornos de ejecución aislados; es el estado más difícil	Quien tenga acceso privilegiado al sistema en ejecución

// EL MALENTENDIDO MÁS CARO DEL SECTOR

«Tenemos cifrado de disco» suele presentarse como si resolviera los tres estados. Resuelve uno, y solo parcialmente: **el disco cifrado únicamente protege mientras el servidor está apagado**. Encendido, el sistema descifra de forma transparente para cualquiera que consulte.

HALLAZGO H3 A LA LUZ DE ESTO

Coopaburrá declaró el dato «protegido» en 2019 porque tenía cifrado de disco completo. Con lo que ya sabemos, veamos qué protege realmente y qué no.

AMENAZA	¿EL CIFRADO DE DISCO LA DETIENE?	QUÉ HARÍA FALTA
Robo físico de un servidor apagado	Sí	Nada más. Aquí el control funciona
Un disco dado de baja sin borrar	Sí	Nada más, si la llave se destruye
Consulta de un empleado con acceso de lectura	No	Cifrado a nivel de campo, enmascaramiento y registro de consultas
Una falla en el portal que devuelva datos	No	Cifrado de campo y control en la aplicación
Copia de la base hecha por el proveedor del core	No	Cifrado de campo con llave que el proveedor no tenga

// LA PREGUNTA PARA EL INFORME

Once personas tienen acceso de lectura a la base. ¿Cuántas necesitan ver la cédula y el saldo para hacer su trabajo? **Esa pregunta vale más que cualquier recomendación de algoritmo.**

EL CIFRADO DE DISCO POR DENTRO

Vale la pena ver cómo funciona para entender con precisión qué protege. La llave vive en un lugar muy concreto mientras el servidor está encendido.

// CÓMO FUNCIONA

Cada sector del disco se cifra con AES en modo XTS, pensado para que el cifrado ocupe lo mismo que el dato y cada sector se escriba por separado.

Al encender, la llave se desbloquea con una contraseña, un chip del equipo o un servidor de llaves, y queda cargada en memoria.

Desde ese momento el sistema descifra de forma transparente todo lo que cualquiera lea.

// LO QUE ESO IMPLICA

No hay control de quién lee: el disco no distingue a un administrador de un atacante con sesión en el servidor.

XTS no autentica: una alteración del disco no se detecta, solo produce datos corruptos.

La llave en memoria se puede extraer de un equipo encendido o recién apagado: está documentado desde 2008.

// LA FRASE PARA EL INFORME DE H3

El cifrado de disco de Coopaburrá es un control contra el robo del medio físico, y funciona para eso. **No es un control de acceso a los datos**, y el informe de 2019 lo presentó como si lo fuera.

TRES FORMAS DE CIFRAR UNA BASE DE DATOS

La recomendación para el hallazgo H3 va a ser una de estas tres, y la diferencia entre ellas es quién puede ver el dato en claro.

OPCIÓN	CÓMO FUNCIONA	QUIÉN VE EL DATO EN CLARO	COSTO
Cifrado transparente	El motor cifra los archivos. La aplicación no se entera	Cualquiera que consulte la base, incluido el administrador y el proveedor	Bajo
Cifrado por columna	El motor cifra solo ciertos campos con llaves separadas	Quien tenga permiso sobre esa llave, no todo el que consulte	Medio
Cifrado en la aplicación	El dato llega ya cifrado al motor; la llave nunca está en la base	Solo la aplicación. Ni el administrador ni el proveedor	Alto

// LA RESTRICCIÓN DEL CASO

El contrato con el proveedor del core dice que **cualquier cambio en el esquema de datos se cotiza aparte y requiere su aprobación**. Eso encarece las dos últimas opciones y hay que decirlo en la recomendación.

CIFRADO EN SOBRE: UNA LLAVE PARA EL DATO, OTRA PARA LA LLAVE

El patrón que usa toda la industria para cifrar grandes volúmenes, y el que resuelve a la vez la rotación y la custodia. Aparece en cada servicio de llaves y en cada módulo de hardware.

CIFRADO EN SOBRE • ENVELOPE ENCRYPTION

Para cifrar un registro:

1. Se genera una llave de datos nueva, al azar (DEK)
2. Se cifra el registro con esa llave, en modo autenticado
3. Se cifra la llave de datos con la llave maestra (KEK)
4. Se guarda, junto al registro, la llave de datos YA CIFRADA

La llave maestra nunca sale del módulo de hardware ni del servicio de llaves.

Rotarla significa volver a cifrar llaves pequeñas, no 2,3 TB de datos.

// POR QUÉ RESUELVE LO QUE PARECÍA IMPOSIBLE

La llave que importa vive en un solo lugar protegido, y las miles de llaves de datos pueden estar al lado del dato porque están cifradas. **Es la respuesta al problema de rotación de la diapositiva siguiente** y la base de la jerarquía de llaves de la sesión 6.

CÓMO SE BUSCA SOBRE UN DATO CIFRADO

El problema práctico que tumba más proyectos de cifrado de campo. Si cada cifrado de la misma cédula es distinto, ¿cómo se encuentra a un asociado por su cédula?

TÉCNICA	CÓMO PERMITE BUSCAR	QUÉ REVELA
Cifrado con vector aleatorio	No permite: cada cifrado de la misma cédula es distinto	Nada. Es lo más seguro y lo menos útil para consultar
Cifrado determinista	La misma cédula produce siempre el mismo cifrado	Qué registros comparten valor: el problema del escudo, en pequeño
Índice ciego	Se guarda aparte un HMAC de la cédula con otra llave, y se busca por él	Igualdad, y solo a quien tenga la llave del índice
Tokenización	El dato se reemplaza por un sustituto sin relación matemática con él	Nada del dato original. Se ve en la sesión 6

// LA DECISIÓN PARA EL HALLAZGO H3

La cédula de los 142.000 asociados se consulta todo el día. **Cifrarla sin prever cómo se va a buscar es la forma más rápida de que el proyecto se cancele por rendimiento.** La entrega 2 tiene que decir qué técnica y por qué.

DATOS EN USO: EL ESTADO MÁS DIFÍCIL

Para procesar un dato hay que descifrarlo, y en ese instante está en claro en la memoria. Dos tecnologías atacan ese problema, y conviene conocerlas para evaluar lo que prometen los proveedores.

// ENTORNOS DE EJECUCIÓN CONFIABLES

El procesador cifra la memoria de un proceso o de una máquina virtual completa, de modo que ni el administrador del servidor ni el de la nube pueden leerla.

Incluyen atestación: una prueba firmada de qué código corre dentro.

Maduros y disponibles hoy en los principales proveedores de nube.

// CIFRADO HOMOMÓRFICO

Permite operar sobre datos cifrados sin descifrarlos nunca: sumar saldos cifrados y obtener la suma cifrada.

Existe y funciona desde 2009, pero es órdenes de magnitud más lento que operar en claro.

Útil en casos específicos de analítica. No es una solución general todavía.

// LO QUE SIGNIFICA PARA EL CASO

Ninguna de las dos es prioridad para Coopaburrá: su problema está en el dato en reposo y en quién consulta. **Pero si un proveedor ofrece «cifrado en todo momento», ya saben qué preguntar:** con qué tecnología, y qué pasa con el dato mientras se procesa.

EL OTRO LADO: PERDER LA LLAVE

Cifrar bien introduce un riesgo nuevo que casi nadie evalúa. Si la llave se pierde, el dato se pierde, y eso es un problema de disponibilidad, que ustedes ya trabajaron en continuidad.

// LO QUE PASA SI SE PIERDE LA LLAVE

El dato cifrado es indistinguible de ruido. No hay soporte técnico ni proveedor que lo recupere.

Para 142.000 asociados y 2,3 TB, eso no es un incidente: es el fin de la operación.

Un respaldo cifrado cuya llave se perdió es un archivo inútil que ocupa espacio.

// CÓMO SE MANEJA

Custodia con al menos dos personas y doble control, de modo que ninguna pueda actuar sola ni perder la única copia.

Copia de resguardo de la llave, guardada en un lugar distinto al dato que protege.

Procedimiento de recuperación probado, no solo documentado.

// LA IRONÍA DEL HALLAZGO H4

Coopaburrá guarda la llave junto al respaldo, lo cual anula la protección. Pero guardarla lejos sin un procedimiento de custodia produce el riesgo contrario: perderla y quedarse sin respaldos. **La respuesta correcta no es esconder la llave: es administrarla.**

UN RESPALDO CIFRADO BIEN HECHO

Con todo lo de hoy ya se puede describir cómo debería ser el respaldo de Coopaburrá. Es, en la práctica, el esqueleto de la recomendación para H4 en la entrega 2.

- 01** **Una llave de datos nueva por cada respaldo, generada al azar**
Nunca derivada de una contraseña con la opción que usa la evidencia C.
- 02** **Cifrado autenticado del archivo completo**
Para que una alteración en la bodega de Sabaneta se detecte al restaurar, y no después.
- 03** **La llave de datos, envuelta por una llave maestra que vive en un servicio de llaves**
El archivo lleva su llave de datos cifrada; la maestra nunca sale del servicio.
- 04** **Restaurar exige una autorización registrada**
Quien opera el respaldo no puede descifrarlo solo: separación de funciones.
- 05** **Prueba de restauración periódica y documentada**
Un respaldo que nunca se ha restaurado no es un respaldo: es una esperanza.

QUÉ SIGNIFICA ROTAR UNA LLAVE

Rotar suena trivial hasta que se calcula. Es una de las decisiones donde el costo operativo determina el diseño, y por eso conviene pensarlo antes de cifrar, no después.

PREGUNTA	EN COOPABURRÁ	IMPLICACIÓN
Cuánto dato hay que volver a cifrar	2,3 TB en el core, más el histórico de respaldos	Con una ventana de cuatro horas los domingos, no cabe en una sola noche
Se puede rotar sin descifrar todo	Solo si se diseñó con cifrado en sobre: una llave de datos protegida por otra llave	Rotar la llave externa es inmediato; rotar la interna obliga a volver a cifrar
Qué pasa con lo ya archivado	Los contratos de hipoteca deben seguir legibles veinte años	Hay que conservar las llaves antiguas de forma segura, no destruirlas
Quién autoriza y quién ejecuta	Hoy nadie. No hay custodios ni procedimiento	Es parte de la política de gestión de llaves de la sesión 6

SECCIÓN

05

LABORATORIO 2

Cincuenta y cinco minutos · Modos, la línea de respaldo de Coopaburrá y Python

QUÉ HACE REALMENTE LA OPCIÓN -k

Necesario para el ejercicio 3. Las herramientas ofrecen dos formas de darles una llave, y no son lo mismo aunque se parezcan en la línea de comandos.

OPCIÓN	QUÉ RECIBE	QUÉ HACE CON ESO
-K mayúscula	La llave en hexadecimal, exactamente los bits que se van a usar	La usa tal cual. Es lo correcto cuando ya se tiene una llave generada al azar
-k minúscula	Una contraseña de texto	La pasa por una función de derivación para producir la llave. La calidad depende de esa función y de sus parámetros

// POR QUÉ IMPORTA EN EL CASO

El script de Coopaburrá usa la minúscula con el contenido de un archivo.

Es decir: trata una llave que ya era aleatoria como si fuera una contraseña, y la degrada al pasarla por una derivación pensada para otra cosa.

// LA SEGUNDA TRAMPA

Lo que se escribe en la línea de comandos queda visible para cualquier usuario que liste los procesos mientras el respaldo corre.

La llave no solo está en un archivo: también se asoma cada noche entre las 11:40 y las 2:15.

LOS TRES EJERCICIOS

01 Ejercicio 1 · Reproducir el escudo

Tomen una imagen con zonas de color uniforme, cifrenla en ECB y en CBC conservando la cabecera, y comparen. Entreguen las dos imágenes y la explicación de la diferencia.

02 Ejercicio 2 · Detectar la manipulación

Cifren un texto en CTR y en GCM. Alteren un byte del texto cifrado en ambos casos e intenten descifrar. Documenten qué pasa en cada modo y por qué.

03 Ejercicio 3 · Auditar a Coopaburrá

Analicen la línea real del script de respaldo del caso, evidencia C. Tiene tres problemas distintos y solo uno es evidente. Encuéntrenlos y propongan la línea corregida.

// LO QUE SE ENTREGA Y CÓMO SE CALIFICA

Una página por equipo al final del bloque. Se evalúa el análisis, no el resultado: un ejercicio que funcionó sin explicación del porqué vale la mitad que uno que falló con un diagnóstico correcto.

COMANDOS DE ARRANQUE

Suficiente para empezar. En Windows van en Git Bash —no en cmd ni PowerShell—, que trae OpenSSL y las órdenes head, tail y cat. Lo demás está en la guía de laboratorio.

LABORATORIO 2 • PUNTO DE PARTIDA

Ejercicio 1 – separar la cabecera y cifrar solo los píxeles (BMP de muestra: escudo-plano.bmp)

```
head -c 54 escudo-plano.bmp > cab.bin      # la cabecera del BMP son 54 bytes
```

```
tail -c +55 escudo-plano.bmp > pix.bin     # el resto son los píxeles
```

```
openssl enc -aes-256-ecb -in pix.bin -out ecb.bin -K <llave_hex> -nopad
```

```
openssl enc -aes-256-cbc -in pix.bin -out cbc.bin -K <llave_hex> -iv <vi_hex> -nopad
```

```
cat cab.bin ecb.bin > escudo-ecb.bmp      # unir cabecera + píxeles para poder abrirlo
```

```
cat cab.bin cbc.bin > escudo-cbc.bmp
```

Ejercicio 2 – cifrado autenticado frente a cifrado a secas

```
openssl enc -aes-256-ctr -in datos.txt -out datos.ctr -K <llave_hex> -iv <vi_hex>
```

(para GCM usen la biblioteca del lenguaje: la línea de comandos no lo expone bien)

Generación de llave y vector, como el martes

```
openssl rand -hex 32      # llave de 256 bits
```

```
openssl rand -hex 16      # vector de inicialización
```

LABORATORIO 2 · EL EJERCICIO EN PYTHON

El ejercicio 2 hecho con la librería cryptography, que es la de referencia en Python: cifrado autenticado, alteración de un byte y verificación de la etiqueta.

```
LABORATORIO 2 · PYTHON 3 + CRYPTOGRAPHY
```

```
# pip install cryptography
import os
from cryptography.hazmat.primitives.ciphers.aead import AESGCM

llave = AESGCM.generate_key(bit_length=256)
nonce = os.urandom(12)                # 96 bits, distinto cada vez
c = AESGCM(llave).encrypt(nonce, b"VALOR=0000100000", b"cuenta=4471")

alterado = bytearray(c); alterado[6] ^= 0x09    # el ataque del error 2
AESGCM(llave).decrypt(nonce, bytes(alterado), b"cuenta=4471")    # → InvalidTag
```

// LO QUE VA EN EL INFORME

Repitan el ataque con AES en modo CTR, sin etiqueta: el descifrado entrega «VALOR=9000100000» sin quejarse. **La diferencia entre las dos salidas es la diferencia entre cifrar y proteger.** Y respondan: ¿qué pasaría si el nonce se repitiera en dos registros?

LA LÍNEA QUE VAN A AUDITAR

Evidencia C del expediente. Es la línea real del programador de tareas de Coopaburrá, la que produce el respaldo diario que viaja a Sabaneta los viernes.

EVIDENCIA C • SCRIPT DE RESPALDO DE COOPABURRÁ

```
openssl enc -aes-256-cbc -in respaldo_diario.sql -out respaldo_diario.enc \  
-k $(cat /opt/backup/llave.txt)
```

// PISTA 1 • LO EVIDENTE

¿Dónde está la llave y quién puede leerla? ¿Y qué viaja en el disco que sale de la sede?

// PISTA 2 • LO QUE ESTÁ EN LA OPCIÓN

La opción usada no es la misma que recibe una llave binaria. Averigüen qué hace exactamente con lo que se le pasa, y qué se deriva de ahí.

// PISTA 3 • LO QUE NO ESTÁ

Comparen el modo elegido con la tabla «Cuál usar y cuándo». Si mañana alguien altera el archivo de respaldo en la bodega, ¿la cooperativa se daría cuenta al restaurarlo?

LISTA PARA AUDITAR CUALQUIER CIFRADO SIMÉTRICO

Consérvenla. Sirve para el informe de Coopaburrá y para el resto de su vida profesional: son las preguntas que hay que hacer frente a cualquier sistema que diga estar cifrado.

- 01** **Qué algoritmo y qué longitud de llave**
Si la respuesta es «cifrado» a secas, ahí ya hay un hallazgo.
- 02** **Qué modo de operación**
Y si es CBC o CTR, dónde está la autenticación que les falta.
- 03** **De dónde sale el vector o el contador, y si se repite alguna vez**
Debe venir de un generador criptográfico y ser distinto en cada operación.
- 04** **De dónde sale la llave y quién la conoce**
Generada al azar o derivada de una contraseña. Cuántas personas y sistemas la tienen.
- 05** **Dónde vive la llave y quién responde por ella**
Nunca junto al dato que protege. Con nombre y cargo del custodio.
- 06** **Cada cuánto se rota y qué pasa si se pierde**
Si no hay respuesta, hay dos hallazgos más.

LO QUE LLEVAMOS DE LA SESIÓN

01

El modo de operación importa más que el algoritmo

AES-256 en ECB deja ver el escudo. El mismo AES-256 en CBC no deja ver nada.

02

Cifrar no es proteger

Confidencialidad sin integridad permite manipulación controlada. Por eso GCM es la respuesta por defecto.

03

Nunca se repite un vector ni un contador

Es el error del martes con otro nombre, y en modo de flujo anula el cifrado por completo.

04

El cifrado de disco protege un solo escenario

El servidor apagado. Encendido, los once que consultan la base ven todo en claro.

05

Para auditar basta con tres preguntas

Qué algoritmo, qué modo, de dónde sale el vector. Con eso se sabe si el dato está protegido o solo lo parece.

SEGUNDA PARTE DEL PRODUCTO

Se entrega al inicio de la sesión 3: análisis de la protección de datos en reposo y en respaldos, hallazgos H3 y H4.

SECCIÓN DEL ENTREGABLE

QUÉ DEBE CONTENER

Qué protege hoy cada mecanismo

Para el cifrado de disco y para el de respaldos: contra qué amenaza sirve y contra cuál no, con la tabla «Hallazgo H3 a la luz de esto» como modelo

Los tres problemas de la evidencia C

Identificados, explicados y con la línea corregida

Qué datos exigen cifrado de campo

Cuáles de los datos de los 142.000 asociados, y por qué esos y no todos

Qué cuesta y qué implica

El contrato del core no permite cambiar el esquema sin cotización. Eso condiciona la recomendación y hay que decirlo

TRABAJO INDEPENDIENTE HASTA LA SESIÓN 3

12 h

TOTAL ENTRE
JUEVES Y MARTES

4 h

LECTURA
PREVIA

8 h

ENTREGA 2 E INFORME
DEL LABORATORIO 2

Lectura previa · 4 horas

NIST SP 800-38D

Recommendation for GCM and GMAC, secciones 5 y 8: qué garantiza el modo y la regla de unicidad del vector. 1,5 horas.

Katz y Lindell (2020)

El capítulo de funciones resumen y sus aplicaciones: las tres propiedades y la construcción encadenada. 1,5 horas.

OWASP

Password Storage Cheat Sheet, completa: cómo se guardan hoy las contraseñas. Una hora. Es la base del bloque 6.

// CONDICIÓN DE ENTRADA A LA SESIÓN 3

El martes se asume sabido qué es una función resumen y qué propiedades promete: la sesión arranca en por qué MD5 y SHA-1 murieron. Las 8 horas de elaboración son la entrega 2 (6 h, en equipo) y el informe del laboratorio (2 h).

LO QUE VIENE EL MARTES

Sesión 3: funciones resumen, autenticación de mensajes y contraseñas. Es la sesión que resuelve los dos hallazgos que hicieron posible el fraude.

// BLOQUE 1 • RESÚMENES Y AUTENTICACIÓN

Qué es una función resumen y por qué MD5 y SHA-1 quedaron fuera.

La diferencia entre integridad y autenticidad, con el código de autenticación de mensajes.

Por qué HMAC-SHA256, que es correcto, no le sirvió a Coopaburrá.

// BLOQUE 2 • CONTRASEÑAS Y LABORATORIO

Por qué una contraseña nunca se cifra ni se resume a secas: se deriva con factor de trabajo.

Laboratorio: atacar la muestra de la tabla de usuarios del caso, evidencia B, y medir cuánto cambia con una función de derivación moderna.

Primera evaluación de conocimiento del módulo.

SIGLAS DE LA SESIÓN · 1 DE 2

AES

Advanced Encryption Standard — Estándar de cifrado avanzado. Cifrado de bloque de 128 bits, adoptado por el NIST en 2001.

DES

Data Encryption Standard — Estándar de cifrado de datos de 1977, con llave de 56 bits. Su versión triple se retiró en 2023.

ECB / CBC / CFB / OFB / CTR

Electronic Codebook, Cipher Block Chaining, Cipher Feedback, Output Feedback, Counter — Modos de NIST SP 800-38A.

GCM / GMAC

Galois/Counter Mode — Modo de cifrado autenticado. GMAC es su variante que solo autentica, sin cifrar.

IV

Initialization Vector — Vector de inicialización. Debe ser único con cada llave; en GCM se le llama también nonce.

DEK / KEK

Data Encryption Key / Key Encryption Key — Llave de datos y llave que cifra llaves, en el cifrado en sobre.

EFF

Electronic Frontier Foundation — Organización civil estadounidense que construyó en 1998 la máquina que rompió DES.

FIPS

Federal Information Processing Standards — Normas federales de procesamiento de información de Estados Unidos, del NIST.

HMAC

Hash-based Message Authentication Code — Código de autenticación de mensajes basado en una función resumen. Sesión 3.

IETF / RFC

Internet Engineering Task Force / Request for Comments — El organismo de estándares de internet y su serie de documentos.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

SIGLAS DE LA SESIÓN · 2 DE 2

IUE

Institución Universitaria de Envigado. Su escudo es la imagen de la demostración de ECB.

MB / TB

Megabyte / Terabyte — Un millón y un billón de bytes. El core de Coopaburrá ocupa 2,3 TB.

MD5 / SHA-1

Message Digest 5 / Secure Hash Algorithm 1 — Funciones resumen rotas por colisiones. Sesión 3.

NIST / SP

National Institute of Standards and Technology / Special Publication — El instituto de normas de Estados Unidos y su serie técnica.

POODLE

Padding Oracle On Downgraded Legacy Encryption — Ataque de oráculo de relleno de 2014 contra SSL 3.0.

RC4

Rivest Cipher 4 — Cifrado de flujo de 1987 sin autenticación, prohibido en el canal seguro desde 2015.

RSA

Rivest, Shamir y Adleman — Algoritmo de llave pública de 1977. Sesión 4.

XOR

Exclusive OR — O exclusivo. Operación bit a bit: convierte un cambio en el cifrado en el mismo cambio en el texto claro.

EUROCRYPT / LNCS

Conferencia europea anual de criptografía / Lecture Notes in Computer Science, la serie donde se publican sus actas.

XTS

XEX-based Tweaked-codebook mode with ciphertext Stealing — Modo de AES para discos. Cifra por sector y no autentica.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

REFERENCIAS DE LA SESIÓN

NIST. (2023).	FIPS 197-upd1: Advanced Encryption Standard (AES).	Estructura del algoritmo, rondas y tamaños de llave
NIST. (2001).	SP 800-38A: Recommendation for block cipher modes of operation: Methods and techniques.	Modos ECB, CBC, CFB, OFB y CTR
NIST. (2007).	SP 800-38D: Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC.	Secciones 5 y 8 · lectura previa de la sesión 3
NIST. (2019).	SP 800-131A Rev. 2: Transitioning the use of cryptographic algorithms and key lengths.	Retiro del triple DES a partir de 2023
Vaudenay, S. (2002).	Security flaws induced by CBC padding. EUROCRYPT 2002, LNCS 2332, 534–545.	El ataque de oráculo de relleno
Nir, Y. y Langley, A. (2018).	RFC 8439: ChaCha20 and Poly1305 for IETF protocols. IETF.	La alternativa a AES en software
Katz, J. y Lindell, Y. (2020).	Introduction to modern cryptography (3. ^a ed.). CRC Press.	Cifrado de llave privada, modos y cifrado autenticado

// ACCESO A LAS FUENTES

Las publicaciones del NIST y los RFC de la IETF son de acceso libre. Los libros y artículos se consultan en las bases de datos de la Institución; no está autorizado el uso de copias obtenidas por otros medios.